

## 6.0 Arquitetura de rede em nuvem segura

A arquitetura de rede em nuvem engloba uma série de conceitos e tecnologias projetadas para garantir a confidencialidade, integridade e disponibilidade de dados e aplicativos em ambientes baseados em nuvem. A arquitetura de nuvem e as práticas modernas de implantação de software permitem integração, gerenciamento e otimização contínuos de recursos em ambientes baseados em nuvem. Os principais recursos incluem provisionamento sob demanda, elasticidade e escalabilidade, que permitem implantação rápida e ajustes dinâmicos nos recursos de computação, armazenamento e rede, conforme necessário.

Além disso, as tecnologias de multilocação e virtualização permitem o compartilhamento e isolamento eficiente de recursos entre diversos usuários e cargas de trabalho. A arquitetura de nuvem também emprega balanceamento de carga e ajuste de escala automático para distribuir cargas de trabalho uniformemente e manter alta disponibilidade e desempenho. Além disso, as estratégias híbrida e multinuvem permitem que as organizações usem vários provedores de serviços de nuvem, reduzindo a dependência de um fornecedor específico e promovendo uma infraestrutura mais resiliente e econômica.

Nesta lição, você vai fazer o seguinte:

- Resumir o que são serviços seguros de nuvem e virtualização.
- Aplicar soluções de segurança em nuvem.
- Resumir a infraestrutura como conceitos de código.
- Conhecer a Internet das Coisas.
- Revisar os conceitos de arquitetura de confiança zero.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Um [[modelo de implantação em nuvem]] classifica como o serviço é disponibilizado e gerenciado em relação à sua propriedade e provisão. É importante reconhecer que os modelos de implantação têm impactos diferentes em ameaças e vulnerabilidades. Os modelos de implantação em nuvem podem ser categorizados em termos gerais da seguinte forma:

- [[Público (ou multi-tenant)]]: é um serviço oferecido pela Internet por [[provedores de serviços em nuvem (CSPs)]] aos consumidores de nuvem. Com esse modelo, as empresas podem oferecer assinaturas ou opções de pagamento proporcional ao uso e, ao mesmo tempo, fornecer serviços mais simples gratuitamente. Como se

trata de um recurso compartilhado, existem riscos em relação ao desempenho e à segurança. [[Arquiteturas multicloud]] são aquelas em que uma organização utiliza serviços de diversos provedores de serviços em nuvem (CSPs).

- **Privada hospedada:** é um serviço hospedado por um terceiro para uso exclusivo da organização. Isso é mais seguro e pode garantir um melhor desempenho, mas é igualmente mais caro.

[[Privada]]: infraestrutura de nuvem completamente privada e de propriedade da organização. Neste caso, é provável que seja uma unidade de negócios dedicada a gerenciar a nuvem enquanto as outras unidades de negócios a utilizam. Com a computação em [[private cloud (nuvem privada)]], as organizações exercem maior controle sobre a privacidade e a segurança de seus serviços. Esse tipo de método de entrega é voltado mais para serviços bancários e governamentais que exigem um controle de acesso rigoroso nas suas operações.

Uma nuvem privada pode residir no local ou fora do local em relação às outras unidades de negócios. Um link no local pode, obviamente, oferecer um melhor desempenho e é menos provável que esteja sujeito a interrupções (perda de um link de Internet, por exemplo). Por outro lado, uma instalação dedicada externa pode fornecer melhor acesso compartilhado para vários usuários em diferentes locais.

- [[Comunitária]]: é aqui que várias organizações compartilham os custos de nuvem privada hospedada ou totalmente privada. Isso geralmente é feito para combinar recursos em prol de uma preocupação comum, como padronização e políticas de segurança.

Também há soluções de computação em nuvem que implementam uma solução híbrida pública/privada/comunitária/hospedada/no local/fora do local. Por exemplo, uma agência de viagens pode disponibilizar um site de vendas durante a maior parte do ano usando uma nuvem privada, mas pode transferir o site para uma nuvem pública quando uma utilização muito maior estiver prevista.

A flexibilidade é uma das principais vantagens da computação em nuvem, porém, as implicações para os riscos relacionados aos dados devem ser bem compreendidas ao transferir informações entre ambientes de armazenamento privados e públicos.

## Considerações de segurança

Diferentes modelos de arquitetura de nuvem têm implicações de segurança variadas, que devem ser consideradas ao decidir qual deles usar.

- **Arquitetura de locatário único:** fornece infraestrutura dedicada a um único cliente, garantindo que apenas ele possa acessar a infraestrutura. Este modelo oferece o mais alto nível de segurança, pois o cliente tem controle total sobre a infraestrutura. No entanto, pode ser mais cara do que a arquitetura multilocatário, e o cliente é responsável por gerenciar e proteger a infraestrutura.
- **Arquitetura multilocatário:** é quando vários clientes compartilham a mesma infraestrutura, com os dados e aplicativos de cada cliente separados de forma lógica dos outros clientes. Este modelo é econômico, mas pode aumentar o risco de acesso não autorizado ou vazamento de dados se não for devidamente protegido.
- **Arquitetura híbrida:** usa infraestrutura de nuvem pública e privada. Este modelo fornece maior flexibilidade e controle sobre dados e aplicativos confidenciais, permitindo que os clientes armazenem dados confidenciais na infraestrutura de nuvem privada enquanto usam a infraestrutura de nuvem pública para cargas de trabalho

menos sigilosas. No entanto, também requer um gerenciamento cuidadoso para garantir a integração e segurança adequadas entre as nuvens públicas e privadas.

- **Arquitetura sem servidor:** é quando o provedor de nuvem gerencia a infraestrutura e automaticamente aumenta ou reduz a escala verticalmente dos recursos com base na demanda. Este modelo pode ser mais seguro do que as arquiteturas tradicionais porque o provedor de nuvem gerencia e protege a infraestrutura. No entanto, os clientes ainda devem tomar medidas para proteger o acesso aos seus aplicativos e dados.

## Nuvem híbrida

[Nuvem híbrida] geralmente descreve um ambiente de computação que combina infraestruturas de nuvem pública e privada, embora qualquer combinação de infraestruturas em nuvem constitua uma nuvem híbrida. Em uma nuvem híbrida, as empresas podem armazenar dados em uma nuvem privada, mas também aproveitar os recursos de uma nuvem pública quando necessário. Isso permite maior flexibilidade e escalabilidade, além de economia. A nuvem híbrida é muito utilizada porque permite que as empresas aproveitem os benefícios da nuvem privada e pública. As nuvens privadas podem fornecer maior segurança e controle sobre os dados, enquanto as nuvens públicas oferecem escalabilidade mais econômica e acesso a uma gama maior de recursos. Uma nuvem híbrida também permite uma transição mais tranquila para a nuvem no caso das empresas que talvez precisem de mais tempo para migrar todos os seus dados.

Esse modelo também apresenta desafios de segurança, como gerenciar vários ambientes de nuvem e aplicar políticas de segurança consistentes. Um problema é a complexidade de gerenciar vários ambientes em nuvem e integrá-los à infraestrutura local, o que pode criar lacunas de segurança e aumentar o risco de violações de dados. Outra preocupação é a possibilidade de acesso não autorizado a dados e aplicativos, principalmente quando informações confidenciais são armazenadas na nuvem pública. Frequentemente ocorrem erros devido à confusão sobre o limite entre a infraestrutura local (on-premises) e a infraestrutura de nuvem pública. Além disso, o uso de vários provedores de nuvem pode dificultar a aplicação de políticas de segurança consistentes em todos os ambientes.

Uma infraestrutura de nuvem híbrida pode fornecer recursos de redundância de dados, como a replicação de dados no local e na infraestrutura de nuvem. A proteção dos dados pode ser alcançada por meio da redundância, mas isso também pode levar a problemas de consistência de dados decorrentes de impasses na sincronização entre vários locais. Considerando que a conformidade legal é uma preocupação crítica ao implementar qualquer tipo de ambiente de nuvem, as organizações devem garantir que os dados armazenados de forma local e nos componentes de nuvem do ambiente híbrido estejam em conformidade com tais exigências. Isso adiciona complexidade às operações de governança e segurança de dados.

Outra consideração é o estabelecimento e a aplicação de acordos de serviço (SLAs). Os SLAs estipulam formalmente todas as expectativas de desempenho, disponibilidade e suporte entre o provedor de serviços em nuvem e a organização. Garantir os níveis esperados de serviço pode ser um desafio ao lidar com a integração de diferentes sistemas em nuvem e no local. Outras preocupações relacionadas à nuvem híbrida incluem a possibilidade de aumento da latência da rede devido a grandes volumes de transferência de dados entre ambientes locais e em nuvem, o que afeta o desempenho do aplicativo. Da mesma forma, o monitoramento do ambiente híbrido pode ser mais complexo devido à necessidade de conhecimento e ferramentas especializados.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Além do modelo de propriedade (pública, privada, híbrida ou comunitária), os [[modelos de serviços em nuvem]] costumam ser diferenciados pelo nível de complexidade e pela quantidade de pré-configuração oferecida. Esses modelos são conhecidos como algo ou [[qualquer coisa como serviço (XaaS)]]. As três implementações mais comuns são infraestrutura, software e plataforma.

## Software como serviço

[[Software como serviço (SaaS)]] é um modelo de disponibilização de aplicações de software. Em vez de comprar licenças de software para um determinado número de vagas, uma empresa acessa o software hospedado nos servidores de um fornecedor utilizando um acordo de pagamento conforme o uso ou concessão (sob demanda). A infraestrutura virtual permite que os desenvolvedores provisionem aplicativos sob demanda muito mais rapidamente. Os aplicativos são desenvolvidos e testados na nuvem sem a necessidade de testá-los e implantá-los em computadores de clientes. Exemplos incluem Microsoft Office 365 ([microsoft.com/en-us/microsoft-365/enterprise](https://www.microsoft.com/en-us/microsoft-365/enterprise)) (<https://www.microsoft.com/en-us/microsoft-365/enterprise>), Salesforce ([salesforce.com](https://www.salesforce.com/)) (<https://www.salesforce.com/>) e Google Workspace ([workspace.google.com](https://workspace.google.com/)) (<https://workspace.google.com/>).

## Plataforma como serviço

[[Platform as a service (PaaS) (plataforma como um serviço)]] fornece recursos em algum lugar entre SaaS e IaaS. Uma solução típica de PaaS fornece servidores e infraestrutura de rede de armazenamento (como no IaaS), mas também uma plataforma de aplicativo/banco de dados da Web de várias camadas. Esta plataforma pode ser baseada em Oracle e MS SQL ou PHP e MySQL. Exemplos incluem Oracle Database ([oracle.com/database](https://www.oracle.com/database/)) (<https://www.oracle.com/database/>), Microsoft Azure SQL Database ([azure.microsoft.com/services/sql-database](https://azure.microsoft.com/services/sql-database/)) (<https://azure.microsoft.com/services/sql-database/>) e Google App Engine ([cloud.google.com/appengine](https://cloud.google.com/appengine/)) (<https://cloud.google.com/appengine/>).

Diferentemente do SaaS, essa plataforma não costuma ser configurada para uma finalidade em particular. Os desenvolvedores criariam o software (o CRM ou aplicativo de comércio eletrônico) que seria executado usando a plataforma. O provedor de serviços seria responsável pela integridade e disponibilidade dos componentes da plataforma, e você seria responsável pela segurança do aplicativo criado na plataforma.

# Infraestrutura como um serviço

[[Infrastructure as a Service (IaaS) (infraestrutura como Serviço)]] é um meio de provisionar rapidamente recursos de TI, como servidores, balanceadores de carga e componentes de rede de área de armazenamento (SAN). Em vez de comprar esses componentes e os links de Internet de que eles necessitam, você os aluga conforme necessário no datacenter do provedor de serviços. Alguns exemplos são o Amazon Elastic Compute Cloud([aws.amazon.com/ec2](https://aws.amazon.com/ec2/) (<https://aws.amazon.com/ec2/>)), Microsoft Azure Virtual Machines([azure.microsoft.com/services/virtual-machines](https://azure.microsoft.com/services/virtual-machines/) (<https://azure.microsoft.com/services/virtual-machines/>)), Oracle Cloud([oracle.com/cloud](https://www.oracle.com/cloud/) (<https://www.oracle.com/cloud/>)) e o OpenStack([openstack.org](https://www.openstack.org/) (<https://www.openstack.org/>)).

## Fornecedores terceirizados

Trata-se de entidades externas que fornecem às organizações bens, serviços ou soluções tecnológicas. Na computação em nuvem, fornecedores terceirizados referem-se aos provedores que oferecem serviços em nuvem para empresas usando modelos de infraestrutura, plataforma ou software como serviço. Como empresa terceirizada, é fundamental fazer uma consideração cuidadosa em relação à seleção de provedores de serviços em nuvem, negociação de contratos, desempenho de serviços, conformidade e práticas de comunicação. As organizações devem adotar estratégias robustas de gerenciamento de fornecedores para mitigar os riscos da plataforma de nuvem, garantir a qualidade do serviço e otimizar as implantações em nuvem. Os acordos de serviço (SLAs) são contratos entre organizações e provedores de serviços em nuvem que estipulam os níveis esperados de prestação de serviços. Os SLAs definem métricas, como tempo de atividade, desempenho e tempos de resposta de suporte, além de penalidades ou soluções se os níveis de serviço não forem atendidos. Os SLAs fornecem uma estrutura para responsabilizar os fornecedores pela prestação de serviços nos níveis de desempenho exigidos.

As organizações devem avaliar as práticas de segurança implementadas pelos fornecedores para proteger seus dados confidenciais, incluindo criptografia de dados, controles de acesso, gerenciamento de vulnerabilidades, procedimentos de resposta a incidentes e conformidade regulamentar. Elas também são responsáveis por garantir a conformidade com os requisitos de privacidade de dados, especialmente se lidarem com informações de identificação pessoal (PII) ou atuarem em setores regulamentados. A dependência tecnológica dificulta ou até mesmo impossibilita a mudança para fornecedores ou plataformas alternativas, portanto, as organizações devem avaliar com cuidado a portabilidade, a interoperabilidade e a padronização dos dados para mitigar os riscos de dependência de um fornecedor específico. Estratégias como implantações multinuvem ou em nuvem híbrida podem fornecer flexibilidade e reduzir a dependência de um único fornecedor.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Ao usar a infraestrutura de nuvem, os riscos de segurança são compartilhados, e não transferidos, entre o provedor da nuvem e o cliente. O provedor da nuvem é responsável por proteger a infraestrutura subjacente, enquanto o cliente é responsável por proteger seus aplicativos e dados. É importante escolher um provedor de nuvem que ofereça recursos de segurança robustos, como criptografia, controles de acesso e segurança de rede.

O modelo de responsabilidade compartilhada descreve o equilíbrio de responsabilidades entre um cliente e um provedor de serviços em nuvem (CSP) para implementar a segurança em uma plataforma de nuvem. A divisão de responsabilidades se torna mais ou menos complicada se o modelo de serviço for SaaS, PaaS ou IaaS. Por exemplo, em um modelo SaaS, o CSP faz a configuração e o controle do sistema operacional como parte da oferta do serviço. Por outro lado, em um modelo IaaS, a segurança do sistema operacional é compartilhada entre o CSP e o cliente. Uma [[matriz de responsabilidades]] apresenta essas funções de forma clara, em um formato tabular.

Figura 1. Modelo de responsabilidade

| Responsabilidade                         | Local | IaaS | PaaS | SaaS | FaaS | nuvem de | controles | do CIS | do |
|------------------------------------------|-------|------|------|------|------|----------|-----------|--------|----|
| Classificação e contabilização dos dados | ●     | ●    | ●    | ●    | ●    | ●        | ●         | ●      | ●  |
| Proteção de end-point e cliente          | ●     | ●    | ●    | ●    | ●    | ●        | ●         | ●      | ●  |
| Gerenciamento de identidade e acesso     | ●     | ●    | ●    | ●    | ●    | ●        | ●         | ●      | ●  |
| Controles no âmbito dos aplicativos      | ●     | ●    | ●    | ●    | ●    | ●        | ●         | ●      | ●  |
| Controles de rede                        | ●     | ●    | ●    | ●    | ●    | ●        | ●         | ●      | ●  |
| Estrutura do host                        | ●     | ●    | ●    | ●    | ●    | ●        | ●         | ●      | ●  |
| Segurança                                | ●     | ●    | ●    | ●    | ●    | ●        | ●         | ●      | ●  |

● Cliente na nuvem ● Provedor de nuvem

Descrição

Os cabeçalhos das colunas são: responsabilidade, ambientes locais (on-premises), IaaS, PaaS, SaaS, FaaS, guia complementar dos controles CIS para nuvem e benchmarks CIS foundations.

Os dados são os seguintes:

Classificação e responsabilidade sobre os dados: cliente da nuvem em ambientes locais, IaaS, PaaS, SaaS e FaaS.

Guia complementar dos controles CIS para nuvem: sim. Benchmarks CIS foundations: sim.

Proteção do cliente e dos endpoints: cliente da nuvem para ambientes locais, IaaS e PaaS. Cliente da nuvem e provedor de nuvem para SaaS e FaaS. Guia complementar dos controles CIS para nuvem: sim. Benchmarks CIS foundations: sim.

Gerenciamento de identidade e acesso: cliente da nuvem para ambientes locais e IaaS. Cliente da nuvem e provedor de nuvem para PaaS, SaaS e FaaS. Guia complementar dos controles CIS para nuvem: sim. Benchmarks CIS foundations: sim.

Controles em nível de aplicativo: cliente da nuvem para ambientes locais e IaaS. Cliente da nuvem e provedor de nuvem para PaaS, SaaS e FaaS. Guia complementar dos controles CIS para nuvem: sim. Benchmarks CIS foundations: sim.

Controles de rede: cliente da nuvem para ambientes locais. Cliente da nuvem e provedor de nuvem para IaaS. Provedor de nuvem para PaaS, SaaS e FaaS. Guia complementar dos controles CIS para nuvem: sim. Benchmarks CIS foundations: sim.

Infraestrutura de host: cliente da nuvem para ambientes locais. Cliente da nuvem e provedor de nuvem para IaaS. Provedor de nuvem para PaaS, SaaS e FaaS. Guia complementar dos controles CIS para nuvem: sim. Benchmarks CIS foundations: não. Segurança física: cliente da nuvem para ambientes locais. Provedor de nuvem para IaaS, PaaS, SaaS e FaaS. Guia complementar dos controles CIS para nuvem: não. Benchmarks CIS foundations: não.

Nota:

Function as a Service (FaaS) está associada à computação serverless. Ela permite que desenvolvedores executem trechos individuais de código (ou funções) em resposta a diversos gatilhos, como solicitações HTTP, alterações em bancos de dados ou tarefas agendadas. A função pode ser escalada dinamicamente para lidar com variações de carga, de forma semelhante a outros serviços baseados em nuvem.

Em termos gerais, as responsabilidades do cliente e do provedor de nuvem incluem as seguintes áreas:

#### **Provedor de serviços em nuvem**

- Segurança física da infraestrutura
- Proteção dos computadores, do armazenamento e dos equipamentos de rede
- Proteção dos elementos fundamentais da rede, como a proteção contra DDoS
- Backup e recuperação do armazenamento em nuvem
- Segurança do isolamento de recursos da infraestrutura em nuvem entre locatários
- Controle de acesso e identidade de recursos do locatário
- Segurança, monitoramento e resposta a incidentes na infraestrutura
- Proteção e gerenciamento de datacenters localizados em diferentes regiões

#### **Cliente de serviços em nuvem**

- Gerenciamento de identidade do usuário
- Configuração da localização geográfica para armazenar dados e executar serviços
- Controles de acesso de usuários e serviços aos recursos da nuvem
- Configuração de segurança de dados e aplicativos
- Proteção de sistemas operacionais, quando implantados
- Uso e configuração de criptografia, especialmente a proteção de chaves

Conforme mencionado anteriormente, a divisão de responsabilidades torna-se mais ou menos complexa dependendo do modelo de serviço utilizado. Por exemplo, em um modelo SaaS, a configuração e o controle da rede são realizados pelo CSP como parte da oferta do serviço. Em um modelo IaaS, a responsabilidade pela configuração da rede é compartilhada entre o CSP e o cliente.

Um conceito central importante ao usar recursos em nuvem é que a implementação e o gerenciamento de controles de segurança não são uma iniciativa sem intervenção, e identificar o limite entre as responsabilidades do cliente e do CSP requer um esforço consciente.

Nota:

Identificar o limite entre as responsabilidades do cliente e do provedor da nuvem, em termos de segurança, é imprescindível para reduzir o risco de introduzir vulnerabilidades no ambiente.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

[[Arquitetura de computação centralizada]] refere-se a um modelo em que todo o processamento e armazenamento de dados é realizado em um único local, normalmente em um servidor central. Todos os usuários e dispositivos dependem do servidor central para acessar e processar os dados e dependem da confiabilidade do administrador do servidor e da organização controladora em relação às decisões de segurança e privacidade. Exemplos de arquitetura de computação centralizada incluem computadores mainframe e arquiteturas cliente-servidor.

Por outro lado, a [[arquitetura de computação descentralizada]] é um modelo em que o processamento e o armazenamento de dados são distribuídos por vários locais ou dispositivos. Nenhum dispositivo ou local é responsável por todo o processamento e armazenamento de dados. As arquiteturas de computação descentralizadas são uma tendência de design cada vez mais importante que afeta as infraestruturas modernas.

A escolha entre arquitetura centralizada e descentralizada depende das necessidades e objetivos específicos de uma organização. A arquitetura centralizada é frequentemente usada em grandes organizações com necessidade de controle e gerenciamento rigorosos. Por outro lado, a arquitetura descentralizada é usada em situações em que a resiliência e a flexibilidade são mais importantes do que o controle centralizado.

A arquitetura descentralizada está se tornando cada vez mais popular, pois oferece vários benefícios, como maior tolerância a falhas, escalabilidade e recursos de segurança exclusivos. Estes são alguns exemplos notáveis de arquitetura descentralizada:

- **Blockchain** é uma tecnologia de registro distribuído que permite transações seguras, transparentes e descentralizadas.
- As **redes peer-to-peer (P2P)** são projetadas para distribuir processamento e armazenamento de dados entre os nós participantes, em vez de depender de um servidor central.
- As **redes de distribuição de conteúdo (CDNs)** distribuem conteúdo em vários servidores para melhorar o desempenho, a confiabilidade e a escalabilidade.
- Os **dispositivos da Internet das Coisas (IoT)** podem ser conectados em uma rede descentralizada para compartilhar dados e poder de processamento.
- Os **bancos de dados distribuídos** veiculam dados entre vários servidores, garantindo que estejam sempre disponíveis, mesmo que um servidor fique inativo.
- O **TOR (The Onion Router)** é uma rede que permite comunicação e navegação anônimas. O TOR encaminha o tráfego por meio de uma rede de servidores, ou nós, operados por voluntários para ocultar a localização e a atividade na Internet de um usuário.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Um dos benefícios da nuvem é o potencial de fornecer serviços resilientes a falhas em diferentes níveis, como componentes, servidores, redes locais, sites, datacenters e redes de longa distância (WAN). O provedor de serviços em nuvem (CSP) utiliza uma camada de [[virtualização]] para garantir que os recursos de computação, armazenamento e rede atendam aos critérios de disponibilidade definidos no seu SLA.

No que diz respeito aos níveis de desempenho de armazenamento, [[alta disponibilidade (HA)]] refere-se ao armazenamento provisionado com garantia de 99,99% de tempo de atividade ou superior. Assim como acontece com a arquitetura local, o CSP usa redundância para disponibilizar vários controladores de disco e dispositivos de armazenamento para um pool de recursos de armazenamento. Os dados podem ser replicados entre pools ou grupos, com cada pool suportado por recursos de hardware separados.

## Replicação

A [replicação] de dados permite que as empresas copiem dados para os locais onde eles podem ser utilizados de forma mais eficaz. A nuvem pode ser usada como uma área de armazenamento central, disponibilizando dados a todas as unidades de negócios. A replicação de dados requer conexões de rede de baixa latência, segurança e integridade de dados. Os CSPs oferecem várias modalidades de desempenho de armazenamento de dados ([cloud.google.com/storage/docs/storage-classes](https://cloud.google.com/storage/docs/storage-classes) (<https://cloud.google.com/storage/docs/storage-classes>)). Os termos

“hot storage” (armazenamento a quente) e “cold storage” (armazenamento a frio) referem-se à rapidez com que os dados são recuperados. O armazenamento a quente recupera dados mais rapidamente do que o armazenamento a frio, porém quanto mais rápida a recuperação, maior o custo.

Diferentes aplicativos têm necessidades de replicação próprias. Um banco de dados geralmente precisa de replicação síncrona de baixa latência, pois uma transação em geral não pode ser considerada completa até que tenha sido feita em todas as réplicas. Um mecanismo para replicar arquivos de dados no armazenamento de backup pode não ter requisitos tão altos, dependendo da criticidade dos dados.

## Alta disponibilidade em todas as zonas

Os CSPs dividem o mundo em regiões. Cada região é independente das outras. As regiões são divididas em zonas de disponibilidade, que têm datacenters independentes com sua própria energia, resfriamento e conectividade de rede. Você pode optar por hospedar dados, serviços e instâncias de VM em uma região específica para fornecer um serviço de latência mais baixa aos clientes. O provisionamento de recursos em várias zonas e regiões também pode melhorar o desempenho e aumentar a redundância, mas requer um nível adequado de desempenho de replicação.

Consequentemente, os CSPs oferecem várias modalidades de replicação, que representam diferentes níveis de serviço de alta disponibilidade:

- **Replicação local:** replica seus dados dentro de um único datacenter na região em que a conta de armazenamento foi criada. As réplicas estão frequentemente em domínios de falha e domínios de upgrade separados.
- **Replicação regional** (também chamada de armazenamento com redundância de zona): replica seus dados entre vários datacenters dentro de uma ou duas regiões. Isso protege os dados e o acesso no caso de um único datacenter ser destruído ou ficar off-line.
- **Armazenamento com redundância geográfica (GRS):** replica seus dados para uma região secundária distante da região primária. Isso protege os dados no caso de uma interrupção ou desastre regional.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

A [[virtualização de aplicativos]] é um tipo mais limitado de infraestrutura de desktop virtual (VDI). Em vez de executar toda a área de trabalho do cliente como uma plataforma virtual, o cliente acessa um aplicativo hospedado em um servidor ou transmite o aplicativo do servidor para o cliente para processamento local. A maioria das soluções de virtualização de aplicativos é baseada no Citrix XenApp (antigo MetaFrame Presentation Server), embora a Microsoft

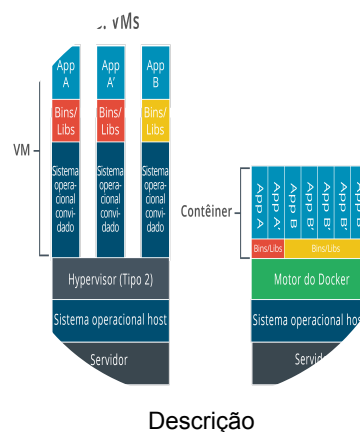
tenha desenvolvido um produto App-V com sua linha Windows Server e a VMware tenha o produto ThinApp. Esses tipos de solução são frequentemente usados com aplicativos de área de trabalho remota HTML5, chamados de soluções “sem cliente” porque os usuários podem acessá-los por meio de um software comum de navegador web.

A [[containerização]] é uma tecnologia poderosa que transformou o empacotamento e a implantação de aplicativos. Os contêineres encapsulam todos os componentes necessários para o software, incluindo código, bibliotecas e configurações, dentro de uma unidade portátil denominada "contêiner". Isolar o software dessa forma garante um comportamento consistente do aplicativo, independentemente da plataforma subjacente em que ele é executado. Contêineres de software são análogos ao uso de contêineres físicos na indústria de transporte marítimo.

Por exemplo, todos os componentes necessários para fornecer um aplicativo web podem ser implantados em contêineres e gerenciados por meio de uma plataforma de contêineres, como o Docker (Docker representa o navio cargueiro que transporta os contêineres). Isso difere significativamente da instalação dos componentes a partir de um repositório de código diretamente "dentro" do sistema operacional e da edição manual de todos os arquivos de configuração associados. Ao utilizar contêineres, diferentes componentes do aplicativo podem ser "trocados", evitando muitas das complexidades associadas à instalação e configuração tradicional de softwares. Métodos tradicionais frequentemente enfrentam problemas porque a configuração do sistema de destino possui versões diferentes de softwares e bibliotecas das exigidas pelos novos componentes. O chamado "pesadelo de dependências" normalmente se manifesta como um ciclo frustrante de tentativas de resolver conflitos ao atualizar ou fazer downgrade de dependências, resultando em novos problemas ou na quebra de funcionalidades já existentes. Isso desperdiça tempo e esforço dos desenvolvedores que precisam navegar por um verdadeiro labirinto de dependências. Aplicações containerizadas evitam isso porque são unidades autocontidas, cada uma contendo uma cópia independente de suas dependências.

Os hipervisores desempenham um papel fundamental na virtualização ao gerenciar múltiplas máquinas virtuais (VMs) em uma única plataforma de hardware. Existem dois tipos principais de hipervisores: Tipo 1 e Tipo 2. Os hipervisores do Tipo 1, também conhecidos como hipervisores bare-metal, são executados diretamente no hardware físico, oferecendo alto desempenho e eficiência, o que os torna ideais para ambientes corporativos. Exemplos incluem VMware ESXi e Microsoft Hyper-V. Os hipervisores do Tipo 2, ou hipervisores hospedados, são executados sobre um sistema operacional hospedeiro e geralmente são usados para desenvolvimento e testes. Exemplos de hipervisores Tipo 2 incluem VMware Workstation e Oracle VirtualBox.

Figura 1. Comparação de VMs e contêineres.



A primeira parte, representando VMs, possui seis camadas. As três camadas mais inferiores são: servidor, sistema operacional hospedeiro e hipervisor (Tipo 2). As próximas três camadas são divididas em três partes cada. A quarta camada está dividida em três sistemas operacionais convidados (guest OS), a quinta camada em três bins/libs e a sexta em app A, app A', e app B. As três camadas superiores são rotuladas coletivamente como VM.

A segunda parte, representando contêineres, possui cinco camadas. As três camadas inferiores são: servidor, sistema operacional hospedeiro e engine Docker. A quarta camada é dividida em duas seções desiguais, rotuladas bins/libs. A quinta camada no topo está dividida em app A, app A', app B, app B', app B', app B', e app B'.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

A [[computação serverless]] é um modelo de computação em nuvem em que o provedor de nuvem gerencia a infraestrutura e aloca recursos automaticamente conforme a necessidade, cobrando apenas pelo uso real da aplicação.

Nesse formato, as organizações não precisam gerenciar servidores e outras infraestruturas, permitindo que se concentrem no desenvolvimento e na implantação de aplicativos.

Alguns exemplos de aplicativos de computação sem servidor incluem chatbots projetados para simular conversas com usuários humanos para automatizar o suporte ao cliente, as vendas, tarefas de marketing e backends móveis. Eles são compostos por componentes de aplicativos móveis do servidor projetados para fornecer processamento de dados, armazenamento, serviços de comunicação e processamento orientado por eventos que responde a eventos ou gatilhos em tempo real, como leituras de sensores, alertas ou outros eventos semelhantes. Os principais provedores de nuvem, como Amazon Web Services (AWS), Microsoft Azure e Google Cloud, oferecem recursos de computação sem servidor, facilitando o aproveitamento dessa tecnologia pelas organizações. A computação sem servidor fornece uma infraestrutura escalável, econômica e fácil de gerenciar para tarefas orientadas por eventos e de processamento de dados.

No padrão serverless, toda a arquitetura é hospedada em uma nuvem. No entanto, ao contrário das ofertas "tradicionais" de [[nuvem privada virtual (VPC)]], serviços como autenticação, aplicações Web e comunicações não são desenvolvidos e gerenciados como aplicativos em execução em instâncias de VM na nuvem. Em vez disso, os aplicativos são desenvolvidos como funções e microsserviços, cada um interagindo com outras funções para facilitar as solicitações do cliente. O faturamento baseia-se no tempo de execução em vez de cobranças por hora. Exemplos deste tipo de serviço incluem AWS Lambda ([aws.amazon.com/lambda](http://aws.amazon.com/lambda) (<http://aws.amazon.com/lambda>)), Google Cloud Functions ([cloud.google.com/functions](http://cloud.google.com/functions) (<http://cloud.google.com/functions>)) e Microsoft Azure Functions ([azure.microsoft.com/services/functions](http://azure.microsoft.com/services/functions) (<http://azure.microsoft.com/services/functions>)).

As plataformas sem servidor eliminam a necessidade de gerenciar instâncias de servidor físicas ou virtuais, portanto, há pouco ou nenhum esforço de gerenciamento de software e patches, privilégios de administração ou monitoramento de segurança do sistema de arquivos. Não é necessário provisionar vários servidores para fins de redundância ou balanceamento de carga. Como todo o processamento ocorre dentro da nuvem, há pouca ênfase no fornecimento de uma rede corporativa. O provedor de serviços gerencia essa arquitetura subjacente. O principal trabalho da segurança de rede é garantir que os clientes que acessam os serviços não tenham sido comprometidos.

A arquitetura sem servidor depende muito da orquestração baseada em eventos para facilitar as operações. Por exemplo, vários serviços são acionados quando um cliente se conecta a um aplicativo. O aplicativo precisa autenticar o usuário e dispositivo, identificar a localização do dispositivo e das suas propriedades de endereço, criar uma sessão, carregar as autorizações para a ação, usar a lógica do aplicativo para processar a ação, ler ou confirmar as informações de um banco de dados e registrar a transação. Essa lógica de projeto difere dos aplicativos escritos em um ambiente baseado em servidor "monolítico".

## Microserviços

[[Microserviços]] são uma abordagem arquitetural para o desenvolvimento de aplicações de software como um conjunto de serviços pequenos e independentes, cada um focado em uma capacidade de negócio específica. Cada microserviço é projetado para ser modular, com uma interface bem definida e uma única responsabilidade. Esta estratégia permite que os desenvolvedores criem e implantem aplicativos complexos com mais eficiência, dividindo-os em componentes menores e mais gerenciáveis.

Os microserviços também permitem que as equipes trabalhem de forma independente em diferentes recursos dos aplicativos, o que facilita a escalabilidade e atualização dos componentes individuais sem afetar todo o sistema. De modo geral, os microserviços prometem auxiliar as organizações a desenvolver aplicativos mais ágeis, escaláveis e resilientes, capazes de se adaptar rapidamente às mudanças nas necessidades de negócios. Os riscos associados a este modelo são em grande parte atribuídos a questões de integração. Embora os componentes individuais operem bem de forma independente, eles geralmente revelam problemas difíceis de isolar e resolver uma vez que estão integrados.

Microserviços e infraestrutura como código (IaC) são tecnologias relacionadas e a arquitetura de microserviços geralmente é implementada usando práticas de IaC. Ao usar IaC, os desenvolvedores podem definir e implantar a infraestrutura como código, o que garante consistência e repetibilidade em diferentes ambientes. Isto permite o desenvolvimento e a implantação mais eficientes dos microserviços, dado que os desenvolvedores podem automatizar de forma independente a infraestrutura de provisionamento e implantação para cada microserviço.

## Mudanças transformadoras

A computação em nuvem oferece muitos serviços arquitetônicos exclusivos que diferem dos serviços locais tradicionais.

Os serviços nativos da nuvem permitem que as organizações ajustem a escala, inovem e otimizem suas operações como nunca antes. Serviços importantes de arquitetura em nuvem incluem ofertas como computação elástica e ajuste de escala automático, que permitem mudanças dinâmicas na potência computacional em resposta às flutuações da demanda. Outros serviços, como a computação sem servidor, alteram significativamente as práticas de desenvolvimento de aplicativos ao abstrair recursos tradicionais do servidor.

Além disso, as plataformas de nuvem fornecem redes de entrega de conteúdo (CDN) avançadas, que otimizam o tráfego web por meio do armazenamento de conteúdo em cache, e o armazenamento de objetos oferece serviços de armazenamento de dados massivos e não estruturados que muitas vezes substituem os servidores de arquivos tradicionais. As ferramentas de gerenciamento de identidade e acesso fornecem recursos avançados de segurança e possibilitam novos métodos de integração de plataforma, enquanto as ferramentas de containerização e orquestração de contêineres estão mudando a forma como os aplicativos são implantados e gerenciados. Os serviços de IA e aprendizagem de máquina, bancos de dados sem servidor, serviços de IoT no backend e recursos de análise de big data expandem ainda mais as possibilidades para as organizações que utilizam a nuvem. Estes serviços de arquitetura em nuvem oferecem um potencial sem precedentes para organizações grandes e pequenas. No entanto, embora esses serviços estejam, sem dúvida, impulsionando inovações transformadoras, a taxa de mudança e os riscos desconhecidos presentes nas plataformas de nuvem apresentam novos problemas significativos de segurança e violações de dados em níveis recordes.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

## Infrastructure as Code (IaC - infraestrutura como código)

[[Infraestrutura como Código (IaC)]] é uma prática de engenharia de software que gerencia a infraestrutura computacional por meio de arquivos de definição legíveis por máquina. Esses arquivos contêm código escrito em um formato específico que pode ser lido e executado por máquinas. Eles gerenciam e provisionam a infraestrutura de computação. Arquivos de definição legíveis por máquina são escritos em formatos como YAML, JSON e HCL (HashiCorp Configuration Language). Eles contêm informações sobre o estado desejado da infraestrutura, incluindo configurações, requisitos de rede, políticas de segurança e outros parâmetros. Ao usar arquivos de definição legíveis por máquina, a infraestrutura pode ser implantada e gerenciada de forma automática e consistente, o que reduz o risco de erros causados pela intervenção manual.

Esses arquivos geralmente são controlados por versão e podem ser tratados como qualquer outro código em um projeto de software. A IaC permite que desenvolvedores e equipes de operações automatizem o processo de implantação e gerenciamento da infraestrutura, o que reduz a probabilidade de erros e inconsistências que podem surgir da configuração manual. Ao usar a IaC, as equipes também podem replicar facilmente a infraestrutura em diferentes ambientes, como desenvolvimento, preparação e produção, e garantir que sua configuração de infraestrutura seja consistente e reproduzível.

Nota:

HCL (HashiCorp Configuration Language) é uma linguagem de configuração desenvolvida pela HashiCorp e usada em ambientes de infraestrutura como código (IaC) para gerenciar e provisionar a infraestrutura de computação. A HCL é semelhante ao JSON e YAML em termos de sintaxe, mas possui alguns recursos adicionais que a tornam mais adequada para o gerenciamento da infraestrutura. Ela suporta variáveis dentro de arquivos de configuração e tem uma sintaxe concisa que facilita a leitura e a gravação. A HCL é usada em muitas ferramentas populares da HashiCorp, incluindo Terraform e Consul.

## Capacidade de resposta

O balanceamento de carga, a computação de borda e o ajuste de escala automático são mecanismos cruciais para garantir a capacidade de resposta, melhorar o desempenho e gerenciar de forma eficaz as cargas de trabalho flutuantes.

- **Balanceamento de carga:** distribui o tráfego de rede em vários servidores ou serviços para melhorar o desempenho e fornecer alta disponibilidade. Na nuvem, os balanceadores de carga são intermediários (proxies) entre usuários e recursos de back-end, como máquinas virtuais ou contêineres. Eles distribuem as solicitações recebidas para diferentes recursos usando algoritmos sofisticados e gerenciam a capacidade do servidor, o tempo de resposta e a carga de trabalho.
- **Computação de borda:** otimiza a localização geográfica dos recursos e serviços para permitir um processamento mais rápido e latência reduzida. Em vez de rotear todos os dados para um datacenter centralizado na nuvem, a computação de borda utiliza recursos de computação distribuídos para minimizar a distância que os dados precisam percorrer, o que reduz a latência da rede e melhora a capacidade de resposta. A computação de borda é particularmente benéfica para aplicativos que exigem processamento em tempo real ou de baixa latência, como dispositivos IoT, redes de entrega de conteúdo (CDNs) e aplicativos sensíveis à latência.
- **Ajuste de escala automático:** processo automatizado que ajusta os recursos computacionais alocados em um aplicativo com base na demanda. Ele permite que a infraestrutura em nuvem aumente ou diminua dinamicamente a escala dos recursos na vertical para atender aos requisitos da carga de trabalho em tempo real. Por exemplo, durante períodos de alta demanda, recursos adicionais são provisionados automaticamente para gerenciar o aumento da carga, o que garante desempenho e capacidade de resposta ideais. Por outro lado, quando a demanda diminui, os recursos desnecessários são liberados de volta para um pool compartilhado visando reduzir os custos operacionais ou torná-los disponíveis para outras cargas de trabalho.

Estes mecanismos otimizam a utilização de recursos, reduzem a latência e permitem que a infraestrutura se adapte sob demanda às mudanças nos padrões das cargas de trabalho, o que resulta em um ambiente de nuvem altamente responsivo e eficiente.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

A IaC é parcialmente facilitada por dispositivos de rede físicos e virtuais que são totalmente configuráveis por meio de scripts e APIs. À medida que as redes se tornam mais complexas, envolvendo milhares de computadores e dispositivos físicos e virtuais, fica mais difícil implementar políticas de rede, como garantir a segurança e gerenciar o fluxo de tráfego.

Com tantos dispositivos para configurar, é melhor dar um passo para trás e considerar um modelo abstrato de como a rede funciona. Neste modelo, as funções de rede podem ser divididas em três “planos”:

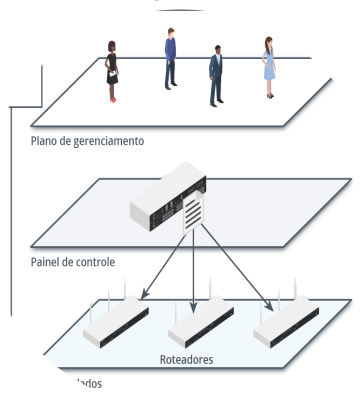
- **Plano de gerenciamento:** monitora as condições do tráfego e o status da rede.
- **Plano de controle:** toma decisões sobre como o tráfego deve ser priorizado, protegido e para onde deve ser encaminhado.
- **Plano de dados:** gerencia a comutação e o roteamento do tráfego e impõe controles de acesso de segurança.

Uma [[aplicação de rede definida por software (SDN)]] pode ser usada para definir decisões de política no plano de controle. Essas decisões são então implementadas no plano de dados por um aplicativo controlador de rede, que faz interface com os dispositivos de rede por meio de APIs. A interface entre os aplicativos SDN e o controlador SDN é descrita como a API “northbound”, enquanto a interface entre o controlador e os dispositivos é a API “southbound”. A

SDN pode ser usada para gerenciar dispositivos físicos compatíveis, mas também switches virtuais, roteadores e firewalls. A arquitetura que possibilita a implantação rápida de redes virtuais utilizando máquinas virtuais (VMs) de uso geral e contêineres é chamada de [[virtualização de funções de rede (NFV)]] ([redhat.com/en/topics/virtualization/what-is-nfv](https://www.redhat.com/en/topics/virtualization/what-is-nfv) (<https://www.redhat.com/en/topics/virtualization/what-is-nfv>)).

Graças a essa arquitetura, os administradores de rede e segurança não têm o trabalho e a complexidade de definir as configurações do dispositivo corretamente para impor uma política desejada. Ela também permite a implantação (ou provisionamento) totalmente automatizada de links de rede, dispositivos e servidores. Isto torna a SDN uma parte importante das mais recentes tecnologias de automação e orquestração.

Figura 1. Dispositivos do plano de dados gerenciados por um dispositivo do plano de controle e monitorados por um plano de gerenciamento



Imagens © 123RF.com.

### Descrição

A rede definida por software (SDN) possui um plano de gerenciamento na parte superior, que inclui pessoas. O plano de gerenciamento monitora o plano de controle, que por sua vez monitora os roteadores no plano de dados.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

A infraestrutura de nuvem pública disponibiliza uma ampla variedade de recursos para garantir alta disponibilidade de atividade e tempo mínimo de inatividade aos clientes. A replicação de dados e a redundância são alguns dos principais recursos, pois os provedores de nuvem pública replicam dados em vários servidores e datacenters para garantir a disponibilidade de dados em caso de falha no servidor ou no datacenter. O ajuste de escala automático também é uma funcionalidade crucial que permite que os recursos sejam escalados automaticamente com base na demanda. Isso, por sua vez, garante que os aplicativos possam suportar altos volumes de tráfego sem tempo de inatividade.

Os provedores de nuvem pública oferecem serviços de recuperação de desastres, que incluem ferramentas de monitoramento e alerta, para detectar e responder proativamente a problemas que possam afetar a disponibilidade. Eles também costumam oferecer acordos de serviço (SLAs), que garantem um certo nível de tempo de atividade e disponibilidade, incluindo créditos ou reembolsos se o provedor não cumprir os compromissos de disponibilidade.

## Considerações

**Custo:** deve se concentrar em soluções que alcancem da melhor forma as metas operacionais, mantendo a confidencialidade, integridade e disponibilidade dos dados, e não apenas o custo na adoção da nuvem. Existem vários modelos de custos associados à execução de serviços na nuvem, como o pagamento por consumo ou por assinatura. A maioria dos provedores de nuvem possui ferramentas projetadas para ajudar a estimar os custos de migração das cargas de trabalho existentes de ambientes locais para a nuvem. O uso de serviços em nuvem envolve uma mudança de despesas de capital (CapEx) para despesas operacionais (OpEx). O CapEx inclui custos iniciais para a compra de hardware, licenças de software e configuração de infraestrutura em uma infraestrutura de TI tradicional local.

Por outro lado, os serviços em nuvem geralmente são pagos conforme o uso, o que permite que as organizações convertam o CapEx em OpEx. Os serviços em nuvem cobram pelo uso e consumo de recursos, o que elimina a necessidade de investimentos iniciais significativos. Este modelo de OpEx oferece flexibilidade, escalabilidade e otimização de custos, pois as organizações pagam apenas pelos recursos usados, o que torna os serviços em nuvem mais econômicos do ponto de vista do alinhamento das despesas com o uso real. No entanto, quando os recursos não são otimizados para serem executados na infraestrutura de nuvem, isso pode apresentar desafios significativos aos benefícios que esse modelo anuncia e gerar custos recorrentes excessivos.

**Escalabilidade:** um dos recursos mais valiosos e atrativos da computação em nuvem. Trata-se da capacidade de expandir e contrair a capacidade dinamicamente, em resposta à demanda sem tempo de inatividade. Existem duas maneiras básicas pelas quais os serviços podem ser escalados. O ajuste de escala vertical descreve a adição de capacidade a um recurso existente, como um processador, memória e capacidade de armazenamento. O ajuste de escala na horizontal descreve a adição de recursos, como mais instâncias (ou máquinas virtuais) para trabalhar em paralelo e aumentar o desempenho.

**Resiliência:** os provedores de nuvem usam hardware redundante, recursos de tolerância a falhas (como clustering) e replicação de dados para armazenar dados em vários servidores e datacenters, garantindo que os dados permaneçam disponíveis se um servidor ou datacenter falhar.

**Facilidade de implantação:** os recursos de nuvem que facilitam a implantação incluem automação, padronização e portabilidade.

- Automatizar a implantação e o gerenciamento de recursos em nuvem reduz a necessidade de intervenção manual e geralmente é alcançado usando gerenciamento de configuração, orquestração de contêineres e infraestrutura como código.
- Configurações, modelos e imagens padronizados simplificam a implantação e garantem consistência.
- A portabilidade garante que aplicativos e serviços possam ser facilmente movidos entre diferentes infraestruturas de nuvem, o que evita a dependência de um fornecedor específico e proporciona maior flexibilidade.

**Facilidade de recuperação:** os provedores de nuvem geralmente oferecem funcionalidades de backup e restauração para que as organizações agendem backups automatizados e restaurem rapidamente os dados em caso de exclusão acidental, corrupção ou falhas no sistema. Os provedores de nuvem geralmente implementam arquiteturas altamente redundantes e tolerantes a falhas, distribuem dados e serviços em vários datacenters ou zonas de disponibilidade e reduzem o risco de perda de dados ou interrupção do serviço, garantindo que as cargas de trabalho façam failover contínuo se um datacenter ou zona sofrer uma interrupção. Além disso, os provedores de nuvem oferecem serviços de recuperação de desastres, que permitem que as organizações repliquem seus ambientes em diferentes regiões, dispondo de recursos de failover no caso de uma catástrofe.

**SLA e ISA:** os acordos de serviço (SLAs) definem os níveis de serviço esperados, que incluem compromissos de desempenho, disponibilidade e suporte entre os provedores de serviços em nuvem e as organizações. É essencial analisar e negociar cuidadosamente os SLAs para garantir que eles estejam alinhados com os requisitos da empresa e protejam adequadamente os interesses da organização. Os acordos de segurança de interconexão (ISAs) estabelecem os requisitos e as responsabilidades de segurança entre a organização e o provedor de serviços em nuvem para proteger dados confidenciais e garantir a conformidade com os regulamentos do setor, o que ajuda a garantir a confidencialidade, integridade e disponibilidade de dados e sistemas dentro do ambiente de nuvem. Os ISAs ajudam a garantir a proteção de dados e sistemas dentro do ambiente de nuvem e definem métodos de criptografia, controles de acesso, gerenciamento de vulnerabilidades e técnicas de segmentação de dados. O acordo também deve especificar a propriedade sobre os dados, direitos de auditoria e procedimentos de backup, recuperação e retenção de dados. Os setores regulamentados devem garantir que seu provedor de serviços em nuvem cumpra os regulamentos relevantes, como RGPD, HIPAA ou PCI DSS. O ISA deve detalhar como o provedor atende a esses requisitos de conformidade e incluir disposições para auditoria e relatórios que demonstrem conformidade contínua. Além disso, o ISA deve abordar o uso de subcontratados e definir claramente as responsabilidades e os requisitos de segurança para sua seleção, bem como o processo de notificação da organização no caso de alterações de subcontratados.

Nota:

O planejamento da recuperação de desastres ainda é essencial e deve incluir procedimentos para restaurar sistemas, dados e aplicativos críticos e se comunicar com clientes e outras partes interessadas. Além disso, testes e validação, acordos de serviço e procedimentos de resposta a incidentes devem ser cuidadosamente considerados ao avaliar a facilidade de recuperação da infraestrutura em nuvem.

**Energia:** os provedores de nuvem priorizam a eficiência energética para reduzir os custos e o impacto ambiental, implantando hardware com eficiência energética, otimizando sistemas de resfriamento e implementando técnicas de gerenciamento de energia. Além disso, a infraestrutura de energia redundante garante alta disponibilidade e é ativada usando várias fontes de alimentação, geradores de backup e sistemas UPS para evitar interrupções no serviço. Os sistemas de monitoramento e gerenciamento de energia permitem que os provedores de nuvem monitorem o consumo de energia em tempo real nos datacenters. Esses sistemas podem ajudar a otimizar a alocação de recursos, identificar infraestrutura com alto consumo de energia e facilitar o balanceamento de carga. Escalabilidade no provisionamento de energia refere-se à capacidade de um provedor alocar dinamicamente recursos de energia com base na demanda do cliente. Eficiência no uso de energia (PUE) é uma métrica usada para medir a eficiência energética do datacenter. Os provedores de nuvem buscam baixos valores de PUE, isto é, a utilização eficiente da energia. Um PUE mais baixo significa que uma proporção maior da energia fornecida ao datacenter é usada para fins de computação, em vez de infraestrutura de suporte.

**Computação:** os recursos de computação na arquitetura de nuvem oferecem a flexibilidade, escalabilidade e eficiência necessárias para gerenciar e utilizar os recursos de computação, que incluem elasticidade, pool de recursos, orquestração, automação e computação sem servidor. Esses recursos contribuem para fornecer ambientes computacionais altamente disponíveis, escaláveis e econômicos na nuvem. As redes virtuais facilitam a comunicação segura e o roteamento de tráfego, enquanto o balanceamento de carga distribui o tráfego de rede para otimizar a utilização de recursos e melhorar o desempenho. O funcionamento em rede também permite a conectividade privada e pública, para que as organizações estabeleçam conexões seguras entre a infraestrutura local e os recursos em nuvem e

tenham acesso externo a aplicativos na nuvem. Além disso, a conectividade em rede suporta arquiteturas escaláveis e distribuídas, permitindo tolerância a falhas, alta disponibilidade e entrega eficiente de conteúdo por meio de serviços especializados, como as redes de entrega de conteúdo (CDNs).



This content is only available on larger screen sizes. Please revisit this page on a larger device.

**Proteção de dados:** os dados e aplicativos são armazenados fora da infraestrutura de gerenciamento privado de uma organização e são essencialmente armazenados “na Internet” logo os erros de configuração podem ter consequências desastrosas. Tomar precauções para proteger os dados usando controles de acesso e criptografia é essencial. Além disso, os planos de recuperação de desastres ainda devem ser desenvolvidos em resposta a eventos catastróficos que afetem a disponibilidade dos recursos em nuvem.

**Atualização de patches:** Os provedores de nuvem devem possuir uma política clara de gerenciamento de patches, incluindo a frequência de lançamento e o tempo de resposta para correção de vulnerabilidades críticas. Além disso, é essencial considerar como é fácil implementar patches a aplicativos e sistemas em execução na infraestrutura de nuvem. A disponibilidade de patches pode ser garantida por meio de diversos recursos, como gerenciamento automatizado de patches, atualizações regulares de software, gerenciamento centralizado de patches, monitoramento de segurança e suporte a softwares de terceiros. Ter um plano para testar e implantar patches garante que os sistemas não sofram com tempo de inatividade não planejado e permaneçam seguros.

Vários fatores podem dificultar ou até mesmo inviabilizar a aplicação de patches de forma uniforme em infraestruturas de nuvem. Um desafio comum é a complexidade dos sistemas em nuvem, o que pode dificultar a identificação e a resolução de vulnerabilidades. Além disso, alguns provedores de nuvem não permitem que os clientes modifiquem a infraestrutura subjacente, o que impossibilita a instalação direta de patches. Em um ambiente de nuvem, o provedor de serviços de nuvem gerencia a infraestrutura subjacente. Esta falta de controle pode dificultar ou mesmo impossibilitar a aplicação de patches de acordo com os requisitos legais e regulamentares ou cronogramas.

## Comunicação e acesso seguros

Uma [[rede de longa distância definida por software (SD-WAN)]] permite que as organizações conectem suas diversas filiais, datacenters e infraestruturas em nuvem por meio de uma rede de longa distância (WAN). Uma das principais vantagens da SD-WAN é sua capacidade de oferecer recursos e considerações de segurança aprimorados. Por exemplo, a SD-WAN usa criptografia para proteger os dados ao longo da rede e pode segmentar o tráfego de rede com base em classificações de prioridade para garantir que os dados críticos estejam totalmente protegidos.

Além disso, a SD-WAN pode rotear o tráfego de forma inteligente com base na aplicação e integrar-se firmemente aos firewalls para fornecer proteção adicional contra ameaças conhecidas. A SD-WAN centraliza o gerenciamento de políticas de segurança de rede para simplificar a aplicação de medidas de segurança em toda a rede.

[[Secure Access Service Edge (SASE)]] combina a proteção de uma plataforma de acesso seguro com a agilidade de uma arquitetura de segurança entregue pela nuvem. A SASE oferece uma abordagem centralizada de segurança e acesso, que fornece proteção de ponta a ponta e agiliza o processo de concessão de acesso seguro a todos os usuários, independentemente da localização. SASE é uma arquitetura de rede que combina tecnologias de rede de longa distância (WAN) e serviços de segurança baseados em nuvem para fornecer acesso seguro a aplicativos e serviços baseados em nuvem.

Ela oferece vários recursos de segurança para ajudar as organizações a proteger suas redes e dados porque opera de acordo com um modelo de segurança de confiança zero. A SASE incorpora o gerenciamento de identidade e acesso (IAM) e assume que todos os usuários e dispositivos não são confiáveis até que sejam autenticados e autorizados. Ela também fornece uma variedade de recursos de prevenção contra ameaças, como prevenção contra invasões, proteção contra malware e filtragem de conteúdo.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Como profissionais de segurança, é essencial entender os conceitos relacionados a sistemas integrados, Internet das Coisas (IoT), controles industriais e arquitetura de confiança zero. A adoção de sistemas integrados e dispositivos IoT continua a aumentar em todos os setores, e eles introduzem desafios de segurança novos e únicos. Compreender estas tecnologias é crucial para implementar medidas de segurança adequadas, garantir resiliência e manter a integridade das infraestruturas críticas.

Os profissionais de segurança também devem estar bem familiarizados com os conceitos de confiança zero, com destaque para o princípio “nunca confie, sempre verifique”. O conhecimento desses conceitos capacita os profissionais de segurança a reduzir os riscos em um mundo cada vez mais complexo e interconectado.

Objetivos abordados no exame:

- 3.1 Comparar e contrastar as implicações de segurança de diferentes modelos de arquitetura.
- 3.2 Considerando determinado cenário, aplicar princípios de segurança para proteger a infraestrutura



This content is only available on larger screen sizes. Please revisit this page on a larger device.

[[Sistemas embarcados]] são utilizados em diversas aplicações especializadas, incluindo eletrônicos de consumo, automação industrial, sistemas automotivos, dispositivos médicos e outros. Alguns exemplos incluem:

- **Eletrodomésticos:** Como refrigeradores, máquinas de lavar e cafeteiras, contêm sistemas embarcados que controlam suas funções e operações.
- **Smartphones e tablets:** contêm uma variedade de sistemas integrados, entre os quais há processadores, sensores e módulos de comunicação.
- **Sistemas automotivos:** assim como os carros modernos, contêm sistemas integrados, que incluem unidades de controle do motor, sistemas de entretenimento e sistemas de segurança, como airbags e freios antibloqueio.
- **Automação industrial:** os sistemas integrados estão presentes em sistemas de controle e máquinas, como robôs, linhas de montagem e sensores.
- **Dispositivos médicos:** marca-passos, bombas de insulina e monitores de glicose no sangue, por exemplo, contêm sistemas integrados que controlam suas funções e fornecem dados aos profissionais de saúde.
- **Aeroespacial e defesa:** Aeronaves, satélites e equipamentos militares utilizam sistemas embarcados para navegação, comunicação e controle.

## Sistemas operacionais em tempo real

Um [[sistema operacional em tempo real (RTOS)]] é um tipo de sistema operacional projetado para uso em aplicações que exigem processamento e resposta em tempo real. Trata-se de sistemas operacionais com fins específicos, que são projetados para altos níveis de estabilidade e velocidade de processamento.

## Exemplos de RTOS

O sistema operacional VxWorks é comumente usado em sistemas aeroespaciais e de defesa. O VxWorks oferece desempenho e confiabilidade em tempo real e, portanto, é adequado para uso em sistemas de controle de aeronaves, sistemas de orientação de mísseis e outros sistemas críticos de defesa. Outro exemplo de um RTOS é o FreeRTOS, um sistema operacional de código aberto usado em muitos sistemas integrados, como robótica, automação industrial e eletrônicos de consumo.

Na indústria automotiva, o RTOS é usado em aplicativos de controle de motor, controle de transmissão e sistemas de segurança ativa. Por exemplo, o padrão AUTOSAR (Automotive Open System Architecture) define uma estrutura para o desenvolvimento de software automotivo, que inclui o uso de RTOS para determinados aplicativos. Em dispositivos médicos, o RTOS é usado em aplicativos como sistemas de monitoramento de pacientes, imagens médicas e sistemas automatizados de administração de medicamentos.

Em sistemas de controle industrial, o RTOS é usado para o controle de processos e aplicativos de automação de fábrica. Por exemplo, o sistema Siemens SIMATIC WinCC Open Architecture usa um RTOS para fornecer desempenho e confiabilidade em tempo real para aplicativos de automação industrial.

## Riscos associados ao RTOS

Uma violação de segurança que envolve RTOS pode ter consequências graves. O software de RTOS pode ser complexo e difícil de proteger, o que torna difícil identificar e resolver vulnerabilidades que podem ser exploradas por invasores.

Outro risco de segurança associado a um RTOS é o potencial para ataques ao sistema. Um invasor que obtenha acesso a um sistema baseado em RTOS pode potencialmente interromper processos críticos ou assumir o controle sobre o sistema para o qual foi projetado. Isto pode levar a sérias consequências considerando os tipos de aplicações que dependem de RTOS, como dispositivos médicos e sistemas de controle industrial. Uma violação de segurança pode resultar em danos a pessoas ou equipamentos.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

## Sistemas de automação de processos e fluxo de trabalho

[[Sistemas de controle industrial (ICSs)]] fornecem mecanismos para fluxo de trabalho e automação de processos. Estes sistemas controlam máquinas usadas em infraestruturas críticas, como de serviços de fornecimento de energia e de água, serviços de saúde, telecomunicações e serviços de segurança nacional. Um ICS que gerencia a automação de processos em um único local é geralmente chamado de sistema de controle distribuído (Distributed Control System, DCS).

Um ICS é composto por dispositivos e equipamentos industriais que possuem controladores lógicos programáveis (PLCs) embarcados. Os PLCs são conectados por meio de uma rede serial de barramento de campo de [[tecnologia operacional (OT)]] ou pelo Ethernet industrial a atuadores que operam válvulas, motores, disjuntores e outros componentes mecânicos, além de sensores que monitoram algum estado local, como a temperatura. A saída e a configuração de um PLC são realizadas por meio de uma ou mais [[interfaces homem-máquina (HMIs)]]. Uma IHM pode ser um painel de controle local ou software em execução em um host de computação. Os PLCs são conectados dentro de um loop de controle, e todo o sistema de automação de processos pode ser gerenciado por um servidor de controle. Outro conceito importante é o [[data historian]] ou seja, um banco de dados que armazena todas as informações geradas pelo loop de controle.

## Controle de supervisão e aquisição de dados (SCADA)

Um [[sistema de supervisão e aquisição de dados (SCADA)]] assume o papel de servidor de controle em ICSs de grande escala e com múltiplos sites. O sistema SCADA geralmente é executado como software em computadores comuns, coletando dados e gerenciando dispositivos e equipamentos industriais com PLCs incorporados, denominados dispositivos de campo. Ele geralmente usa comunicações WAN, como celular ou satélite, para vincular o servidor SCADA a dispositivos de campo.

## Aplicações ICS/SCADA

Estes tipos de sistemas são usados em muitos setores da indústria:

- **Energia** refere-se à geração e à distribuição de energia elétrica. Mais amplamente, os serviços públicos incluem redes de água/esgoto e transporte.
- **Industrial** pode se referir especificamente à mineração e refinamento de matérias-primas, envolvendo fornalhas perigosas de alta temperatura e pressão, prensas, centrífugas, bombas, etc.
- **Fabricação e manufatura** referem-se à criação de componentes e à montagem desses componentes em produtos. Os sistemas embarcados são usados para controlar sistemas de produção automatizados, como forjas, moinhos e linhas de montagem. Estes sistemas devem funcionar com precisão extremamente alta.
- **Logística** refere-se ao transporte de coisas do local onde foram fabricadas ou montadas para onde precisam estar, seja dentro de uma fábrica ou para distribuição aos clientes. A tecnologia embarcada é usada no controle de sistemas automatizados de transporte e elevação, além de sensores para rastreamento de componentes.
- **Instalações** referem-se a sistemas de gerenciamento locais, que geralmente operam sistemas automatizados de aquecimento, ventilação e ar condicionado (Heating, Ventilation, and Air Conditioning, HVAC), iluminação e segurança.

Os ICS e SCADA foram historicamente criados sem levar em conta a segurança da tecnologia da informação, embora agora haja uma grande conscientização sobre a necessidade de impor controles de segurança para protegê-los, especialmente quando operam em um ambiente de rede.

Nota:

Um exemplo notório de um ataque a um sistema integrado é o worm Stuxnet ([wired.com/2014/11/countdown-to-zero-day-stuxnet](http://wired.com/2014/11/countdown-to-zero-day-stuxnet) (<https://www.wired.com/2014/11/countdown-to-zero-day-stuxnet/>)). Ele foi projetado para atacar o software de gerenciamento SCADA em execução em PCs com Windows para danificar as centrífugas usadas pelo programa de combustíveis nucleares do Irã. A Publicação Especial 800-82 do NIST apresenta recomendações para a implementação de controles de segurança em ICS e SCADA.

Os sistemas industriais têm prioridades diferentes dos sistemas de TI. Muitas vezes, estão envolvidos componentes eletromecânicos perigosos, portanto, a segurança é a prioridade absoluta. Os processos industriais também priorizam a disponibilidade e a integridade em detrimento da confidencialidade, invertendo a tríade CIA como a tríade AIC.

A segurança cibernética é fundamental nos sistemas de controle industrial (ICS) e de supervisão e aquisição de dados (SCADA). Estes sistemas estão associados a setores críticos de infraestrutura, como energia, manufatura, transporte e tratamento de água. Os ataques cibernéticos a estes sistemas podem afetar gravemente a segurança pública, a estabilidade econômica e a segurança nacional.

Os sistemas ICS e SCADA controlam e monitoram processos críticos e tecnologias operacionais, tornando-os alvos atraentes para invasores. As consequências dos ataques variam desde apagões generalizados e danos ambientais até perdas econômicas e, inclusive, perda de vidas. Malware, ransomware, acesso não autorizado e ataques direcionados representam riscos significativos para os sistemas ICS e SCADA, e proteções robustas de segurança cibernética, que inclui segmentação de rede, controles de acesso, sistemas de detecção de intrusão, criptografia e monitoramento contínuo, são essenciais para proteger estes sistemas críticos.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

[[Internet das Coisas (IoT)]] refere-se à rede de dispositivos físicos, veículos, eletrodomésticos e outros objetos equipados com sensores, software e conectividade, possibilitando a coleta e a troca de dados.

Sensores são pequenos dispositivos projetados para detectar mudanças no ambiente físico, como temperatura, umidade e movimento. Por outro lado, os atuadores podem executar ações com base em dados coletados por sensores, como acender uma luz ou ajustar um termostato. Os dispositivos IoT se comunicam entre si e com outros sistemas (geralmente baseados em nuvem pública) pela Internet para trocar dados e receber instruções. Os sistemas baseados em nuvem formam um componente essencial das infraestruturas de IoT, pois fornecem a potência computacional necessária para realizar análises de dados nas grandes quantidades de dados gerados pelos dispositivos de IoT.

## Exemplos de IoT

Existem muitos dispositivos e aplicações de IoT em uso hoje. Por exemplo, as casas inteligentes costumam usar sensores e atuadores de IoT para controlar a iluminação, a temperatura e os sistemas de segurança, o que permite que os proprietários monitorem e ajustem suas casas remotamente. As cidades inteligentes também usam a IoT para gerenciar o tráfego, monitorar a qualidade do ar e melhorar a segurança pública. No setor de saúde, dispositivos IoT, como wearables (dispositivos portáteis) e dispositivos implantáveis, podem coletar dados sobre a saúde do paciente e enviá-los aos profissionais de saúde para análise. Na agricultura, os sensores de IoT são usados para monitorar as condições do solo, os padrões climáticos e o crescimento das culturas, o que ajuda os agricultores a tomar decisões mais informadas sobre o plantio e a colheita. Os dispositivos IoT são usados para melhorar a eficiência, conveniência e qualidade de vida em diversos setores da indústria e aplicações.

## Fatores que impulsionam a adoção da IoT

Vários fatores impulsionam a rápida adoção da IoT. A significativa redução no custo de sensores e dispositivos IoT nos últimos anos os tornou mais acessíveis para empresas e consumidores. Isto permitiu o desenvolvimento de uma ampla variedade de aplicações e serviços de IoT que antes eram muito caros de implementar. Os avanços na tecnologia de conectividade, como 5G e redes wireless de baixa potência, tornaram a conexão e o gerenciamento de um grande número de dispositivos IoT mais fáceis e eficientes. Isto também melhorou a velocidade e a confiabilidade da transmissão de dados, permitindo monitoramento e resposta em tempo real. O aumento explosivo de dados gerados por dispositivos IoT levou ao surgimento de novas ferramentas e técnicas de análise de dados, como aprendizado de máquina e inteligência artificial, que ajudam as organizações a analisar grandes quantidades de dados e extrair insights valiosos.

A pandemia da COVID-19 acelerou a adoção da IoT em muitos setores, especialmente na área da saúde, nos quais o monitoramento remoto e a telemedicina se tornaram cada vez mais importantes. À medida que mais organizações reconhecem o valor da IoT, é provável que a adoção continue a crescer nos próximos anos.

## Riscos de segurança associados à IoT

Existem vários riscos de segurança significativos associados à IoT. Um grande risco é o grande número de dispositivos IoT implantados sem medidas de segurança adequadas. Muitos dispositivos IoT são projetados com poder de processamento e memória limitados, o que dificulta a implementação de controles de segurança fortes. Isto pode torná-los vulneráveis a ataques cibernéticos, comprometendo a privacidade dos dados, a integridade do sistema e a segurança física.

Outro risco é a necessidade de mais padronização nos dispositivos e protocolos de IoT. Problemas de compatibilidade podem dificultar a integração de diferentes dispositivos e serviços de IoT. Também podem dificultar a implementação de controles de segurança, uma vez que diferentes dispositivos podem ter diferentes requisitos e protocolos de segurança, tornando-os incompatíveis.

O grande volume de dados gerados pelos dispositivos IoT pode dificultar a proteção de informações confidenciais. À medida que mais dispositivos são conectados à Internet, há um risco crescente de violações de dados e ataques cibernéticos, o que pode resultar no roubo de dados pessoais e confidenciais.

Exemplos de problemas de segurança causados pela implementação ou uso da IoT incluem o ataque do botnet Mirai, que infectou milhões de dispositivos IoT e os usou para lançar ataques distribuídos de negação de serviço (DDoS) massivos em sites e serviços on-line. Em outro caso, um cassino foi hackeado por meio de um termômetro inteligente em um aquário, que foi usado como backdoor para acessar a rede do cassino. Também houve casos de dispositivos IoT hackeados para espionar indivíduos, como babás-eletrônicas e câmeras de segurança domésticas.

Nota:

"Casino Gets Hacked Through Its Internet-Connected Fish Tank Thermometer" <https://thehackernews.com/2018/04/iot-hacking-thermometer.html> (<https://thehackernews.com/2018/04/iot-hacking-thermometer.html>)

Os dispositivos IoT geralmente têm características de segurança ruins por vários motivos. Os dispositivos IoT são normalmente projetados para se concentrar na funcionalidade e não na segurança e têm poder de processamento e memória limitados, o que dificulta a implementação de controles de segurança fortes. Muitos dispositivos IoT devem ser de baixo custo, o que torna difícil para os fabricantes priorizar os recursos de segurança em seu processo de design e desenvolvimento. Muitos dispositivos IoT são lançados às pressas no mercado sem testes de segurança adequados, o que resulta em vulnerabilidades que os criminosos cibernéticos conseguem explorar.

Além disso, os consumidores e as organizações precisam de mais conscientização sobre os riscos de segurança associados aos dispositivos IoT. Muitos usuários e organizações não percebem que seus dispositivos são vulneráveis a ataques cibernéticos e podem não tomar as medidas necessárias para se proteger, como alterar senhas padrão ou atualizar o firmware.

# Diretriz de melhores práticas para IoT

A seguir, fornecemos diretrizes relativas à implementação segura da IoT:

- **The Internet of Things Security Foundation (IoTSEF)** - <https://iotsecurityfoundation.org/> (<https://iotsecurityfoundation.org/>)
- **Industrial Internet Consortium (IIC) Security Framework** - <https://www.iiconsortium.org/iisf/> (<https://www.iiconsortium.org/iisf/>)
- **Cloud Security Alliance (CSA) IoT Security Controls Framework** - <https://cloudsecurityalliance.org/artifacts/iot-security-controls-framework> (<https://cloudsecurityalliance.org/artifacts/iot-security-controls-framework>)
- **European Telecommunications Standards Institute (ETSI) IoT Security Standards** - <https://www.etsi.org/technologies/consumer-iot-security> (<https://www.etsi.org/technologies/consumer-iot-security>)



This content is only available on larger screen sizes. Please revisit this page on a larger device.

# A necessidade emergente de arquiteturas de confiança zero (ZTA)

A crescente dependência das organizações em relação à tecnologia da informação tem impulsionado a necessidade de que os serviços estejam sempre ligados, sempre disponíveis e acessíveis de qualquer lugar. As plataformas em nuvem tornaram-se um componente essencial das infraestruturas de tecnologia, provocando amplas dependências de software e sistema e uma integração generalizada de plataformas. A distinção entre dentro e fora desapareceu. Para uma organização que utiliza forças de trabalho remotas, executa uma combinação de infraestrutura em nuvem pública e local e usa serviços terceirizados e contratados, o risco de violação é muito alto. A equipe e os funcionários usam computadores conectados a redes domésticas, ou pior, Wi-Fi público não seguro. Os sistemas críticos são acessíveis por meio de várias interfaces externas e executam software desenvolvido por entidades externas terceirizadas e contratadas. Além disso, muitas organizações projetam seus ambientes para permitir Bring Your Own Device (BYOD) (traga seu próprio dispositivo).

À medida que estas tendências continuam, a implementação de arquiteturas de confiança zero se tornará mais crítica. Arquiteturas de [[confiança zero]] partem do princípio de que nada deve ser presumido e que todo acesso à rede deve ser continuamente verificado e autorizado. Qualquer usuário, dispositivo ou aplicativo que busque acesso deve ser autenticado e verificado. A arquitetura de confiança zero difere dos modelos de segurança tradicionais baseada na simples concessão de acesso a todos os usuários, dispositivos e aplicativos contidos na rede confiável de uma organização.

O NIST SP 800-207 “Zero Trust Architecture” define a confiança zero como “paradigmas de segurança cibernética que movem as defesas de perímetros estáticos baseados em rede para se concentrar em usuários, ativos e recursos”. Uma arquitetura de confiança zero consegue proteger dados, aplicativos, redes e sistemas contra ataques mal-intencionados e acesso não autorizado de forma mais eficaz do que uma arquitetura tradicional, o que garante que apenas os serviços necessários e de fontes apropriadas sejam permitidos. A confiança zero permite que as organizações ofereçam serviços com base em diferentes níveis de confiança, como fornecer acesso mais limitado a dados e sistemas confidenciais.

- NIST SP 800-207 <https://csrc.nist.gov/publications/detail/sp/800-207/final> (<https://csrc.nist.gov/publications/detail/sp/800-207/final>).

- Modelo de Maturidade de Confiança Zero da CISA <https://www.cisa.gov/zero-trust-maturity-model> (<https://www.cisa.gov/zero-trust-maturity-model>)

# Deperimetrização

Deperimetrização refere-se a uma abordagem de segurança que desloca o foco da defesa dos limites de uma rede para a proteção dos recursos e dados individuais dentro da rede. À medida que as organizações adotam a computação em nuvem, o trabalho remoto e os dispositivos móveis, os modelos tradicionais de segurança baseados em perímetro tornam-se menos eficazes para lidar com as ameaças modernas. Os conceitos de deperimetrização defendem a implementação de várias medidas de segurança em torno de ativos individuais, como dados, aplicativos e serviços. Esta abordagem inclui autenticação robusta, criptografia, controle de acesso e monitoramento contínuo para manter a segurança de recursos críticos, independentemente de sua localização.

## Tendências que impulsionam a desperimetrização

- **Nuvem:** as infraestruturas empresariais são normalmente distribuídas entre plataformas locais e em nuvem. Além disso, as plataformas em nuvem podem ser usadas para distribuir recursos de computação globalmente.
- **Trabalho remoto:** cada vez mais organizações têm adotado equipes de trabalho remotas em regime parcial ou integral. Essas equipes remotas expandem drasticamente a dispersão da empresa. Além disso, os funcionários que trabalham em casa são mais suscetíveis a lapsos de segurança quando se conectam a partir de locais inseguros e usam dispositivos pessoais.
- **Celular:** os smartphones e tablets modernos são geralmente usados como dispositivos de computação primários, pois possuem ampla capacidade de processador, memória, e armazenamento. À medida que seus recursos se expandem, mais e mais dados corporativos são acessados por meio desses dispositivos. Os dispositivos móveis e seus sistemas operacionais associados têm recursos de segurança variados, e muitos dispositivos deixam de ter suporte do fabricante pouco após o lançamento, e com isso não podem ser atualizados ou corrigidos. Além disso, os dispositivos móveis são perdidos ou roubados com muita frequência.
- **Terceirização e contratação:** acordos de suporte frequentemente fornecem acesso remoto a entidades externas. Com isso, a rede do provedor externo pode servir como um ponto de acesso para as organizações clientes.
- **Redes wireless (Wi-Fi):** as redes sem fio estão suscetíveis a uma variedade cada vez maior de ataques, mas muitas vezes as redes wireless estão abertas e desprotegidas ou a chave de segurança da rede é bem conhecida.

## Os principais benefícios de uma arquitetura de confiança zero

- **Maior segurança:** exige que todos os usuários, dispositivos e aplicativos sejam autenticados e verificados antes do acesso à rede.

- **Melhores controles de acesso:** inclui limites mais rigorosos sobre quem ou o que pode acessar recursos e de quais localizações.
- **Governança e conformidade aprimoradas:** Limite o acesso aos dados e proporcione maior visibilidade operacional sobre as atividades de usuários e dispositivos.
- **Maior granularidade:** concede aos usuários acesso ao que precisarem e quando precisarem.

Uma arquitetura de confiança zero requer uma compreensão detalhada dos muitos componentes e tecnologias usados na rede de uma organização. A lista a seguir descreve os componentes essenciais de uma arquitetura de Zero Trust:

- **Segurança de rede e de endpoints:** controla o acesso a aplicativos, dados e redes.
- **Identity and access management (IAM- Gerenciador de identidade e acesso):** garante que apenas usuários verificados possam acessar sistemas e dados.
- **Imposição baseada em políticas:** restringe o tráfego de rede a apenas solicitações legítimas.
- **Segurança na nuvem:** gerencia o acesso a aplicativos, serviços e dados baseados na nuvem.
- **Visibilidade da rede:** analisa o tráfego de rede e os dispositivos em busca de atividades suspeitas.
- **Network segmentation (segmento de rede):** controla o acesso a dados e recursos confidenciais de locais confiáveis.
- **Proteção de dados:** controla e protege o acesso a dados confidenciais, incluindo criptografia e auditoria.
- **Deteção e prevenção de ameaças:** identifica e evita ataques contra a rede e os sistemas conectados a ela.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

A arquitetura de confiança zero é um modelo de segurança que pressupõe que todos os dispositivos, usuários e serviços não são inerentemente confiáveis, independentemente de estarem dentro ou fora do perímetro de uma rede. O modelo de confiança zero exige que todos os usuários e dispositivos sejam autenticados e autorizados antes de acessar os recursos da rede. O modelo de confiança zero inclui vários conceitos fundamentais que fornecem uma solução de segurança abrangente.

- A **identidade adaptativa** reconhece que as identidades do usuário não são estáticas e que a verificação de identidade deve ser contínua e baseada no contexto atual do usuário e nos recursos que ele está tentando acessar.
- A **redução do escopo de ameaças** significa que o acesso aos recursos da rede é concedido com base na necessidade de conhecimento, e o acesso é limitado apenas aos recursos necessários para concluir uma tarefa específica. Este conceito reduz a superfície de ataque da rede e limita os danos que um ataque bem-sucedido pode causar.

- O **controle de acesso orientado por políticas** descreve como as políticas de controle de acesso são usadas para impor restrições de acesso com base na identidade do usuário, postura do dispositivo e contexto da rede.

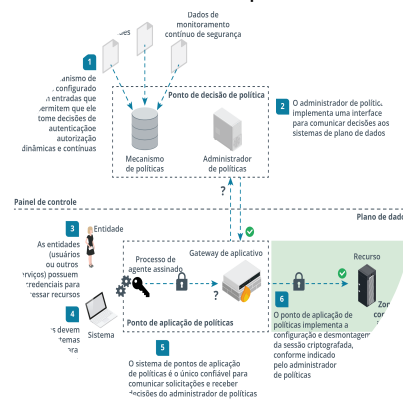
Nota:

A **postura do dispositivo** refere-se ao status de segurança de um dispositivo, que inclui suas configurações de segurança, versões de software e níveis de patch. Em um contexto de segurança, a avaliação da postura do dispositivo envolve a avaliação do status de segurança de um dispositivo para determinar se ele atende a certos requisitos de segurança ou representa um risco para a rede.

# Significado dos planos de controle e dados em modelos de confiança zero

Em uma arquitetura de confiança zero, os planos de controle e dados são implementados separadamente e têm funções diferentes.

Figura 1. Componentes na estrutura da arquitetura de confiança zero do NIST.



## Descrição

Os componentes são os seguintes:

Plano de controle:

1. O mecanismo de políticas é configurado com entradas que permitem tomar decisões dinâmicas e contínuas de autenticação e autorização.
2. O administrador de políticas implementa uma interface para comunicar as decisões aos sistemas do plano de dados.

Plano de dados:

3. Os sujeitos (usuários ou outros serviços) possuem credenciais para acessar os recursos.
4. As entidades devem usar sistemas clientes para fazer solicitações, mas elas não são implicitamente confiáveis.

5. O sistema de ponto de aplicação de políticas é o único autorizado a comunicar solicitações e receber decisões do administrador de políticas.
6. O ponto de aplicação de políticas implementa a configuração e finalização de sessões criptografadas conforme as orientações do administrador de políticas.
7. Essa arquitetura cria uma zona de confiança implícita de escopo e duração limitados para acesso a recursos.

O [[plano de controle]] gerencia as políticas que determinam como usuários e dispositivos são autorizados a acessar os recursos de rede. É implementado por meio de um ponto de decisão de política centralizado. O ponto de decisão de política é responsável por definir políticas que limitam o acesso aos recursos com base na necessidade real, monitorar a atividade da rede em busca de comportamentos suspeitos e atualizar as políticas para refletir as mudanças nas condições da rede e as ameaças à segurança. O ponto de decisão de política é composto por dois subsistemas:

- O mecanismo da política é configurado com identidades e credenciais de sujeito e host, políticas de controle de acesso, threat intelligence atualizada, análises comportamentais e outros resultados de varreduras e monitoramento de segurança de hosts e redes. Esses dados de estado abrangentes permitem definir um algoritmo e métricas para tomar decisões dinâmicas de autenticação e autorização caso a caso para cada solicitação.
- O administrador da política é responsável por gerenciar o processo de emissão de tokens de acesso e estabelecer ou derrubar sessões, com base nas decisões tomadas pelo mecanismo da política. O administrador da política implementa uma interface entre o plano de controle e o plano de dados.

Enquanto os sistemas no plano de controle definem políticas e tomam decisões, os sistemas no plano de dados estabelecem sessões para transferências seguras de informações. No plano de dados, um sujeito (usuário ou serviço) usa um sistema (como um computador, laptop ou smartphone de host de cliente) para fazer solicitações a um determinado recurso. Um recurso é normalmente um aplicativo corporativo em execução em um servidor ou na nuvem. Cada solicitação é mediada por um ponto de aplicação da política. O ponto de imposição pode ser implementado como um agente de software em execução no host do cliente que se comunica com um gateway de aplicativo. O ponto de aplicação da política interage com o administrador da política para configurar um caminho de dados seguro se o acesso for aprovado ou derrubar uma sessão se o acesso for negado ou revogado.

Nota:

Os processos que implementam o ponto de aplicação da política são os únicos autorizados a interagir com o administrador da política. É fundamental estabelecer uma base de confiança para estes processos, para que as decisões resultantes das políticas não possam ser adulteradas.

O caminho de dados estabelecido entre o ponto de aplicação da política e o recurso denomina-se zona de confiança implícita. Por exemplo, o resultado de uma solicitação de acesso bem-sucedida pode ser um túnel IPsec estabelecido entre um processo de agente assinado digitalmente em execução no cliente, um gateway de aplicativo Web confiável e o servidor de recursos. Como os dados são protegidos pela criptografia de transporte IPsec, não é possível nenhuma adulteração por qualquer pessoa com acesso à infraestrutura de rede subjacente (switches, access points, roteadores e firewalls).

O objetivo do modelo de confiança zero é tornar esta zona de confiança implícita tão pequena e transitória quanto possível. As sessões confiáveis só podem ser estabelecidas para transações individuais. Esta abordagem granular ou microssegmentada contrasta com os modelos baseados em perímetro, nos quais os usuários são considerados confiáveis assim que se autenticam e acessam a rede. Na arquitetura de confiança zero, a posição na rede não é motivo suficiente para confiar em uma solicitação da entidade. Da mesma forma, mesmo que um usuário seja nominalmente autenticado, a análise comportamental pode fazer com que uma solicitação seja bloqueada ou uma sessão seja encerrada.

Separar o plano de controle e o plano de dados tem importância significativa porque permite uma arquitetura de rede mais flexível e dimensionável. O plano de controle centralizado garante uniformidade no gerenciamento de solicitações de acesso tanto na rede corporativa gerenciada como na Internet não gerenciada ou em redes de terceiros, independentemente dos dispositivos usados ou da localização do usuário. Isto facilita o gerenciamento de políticas de controle de acesso e o monitoramento da atividade da rede em relação a comportamentos suspeitos. O monitoramento contínuo por meio do plano de controle independente significa que as sessões podem ser encerradas se um comportamento anômalo for detectado.

## Exemplos de arquitetura de confiança zero

| Exemplo                                                                | Descrição                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
|------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Google BeyondCorp                                                      | O modelo BeyondCorp do Google é um exemplo amplamente reconhecido de uma arquitetura de segurança de confiança zero. O BeyondCorp usa um sistema de várias camadas de segurança, que inclui verificação de identidade, verificação do dispositivo e políticas de controle de acesso, para proteger a rede interna do Google. Isto permitiu que o Google fornecesse aos seus funcionários acesso remoto aos recursos da empresa, mantendo a alta segurança. |
| Cisco Zero Trust Architecture (Arquitetura de confiança zero da Cisco) | A Cisco desenvolveu uma arquitetura abrangente de segurança de confiança zero que incorpora segmentação de rede, políticas de controle de acesso e recursos de detecção e resposta a ameaças. A arquitetura foi projetada para proteger contra uma ampla variedade de ameaças cibernéticas, incluindo ameaças internas e ataques externos.                                                                                                                 |
| Palo Alto Networks Prisma Access (Prisma Access da Palo Alto Networks) | O Prisma Access é um serviço de segurança fornecido pela nuvem que usa uma arquitetura de confiança zero para proteger o tráfego de rede. Ele fornece acesso seguro à nuvem e aos recursos da Internet, ao mesmo tempo em que evita a exfiltração de dados e outras ameaças cibernéticas.                                                                                                                                                                  |



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Você deve ser capaz de resumir os conceitos de virtualização e computação em nuvem, bem como entender os conceitos comuns de segurança em nuvem relacionados às funções de computação, armazenamento e rede.

### **Diretrizes para implementar soluções de nuvem seguras**

Siga estas diretrizes para implantar ou estender o uso da infraestrutura de nuvem e virtualização:

- Avalie os requisitos de disponibilidade e confidencialidade, que determinarão o modelo de implantação de nuvem apropriado (público, privado hospedado, privado, comunitário ou híbrido).
- Identifique um modelo de provisionamento de serviços (software, plataforma ou infraestrutura) que melhor se adapte aos requisitos do aplicativo, conforme os recursos de desenvolvimento disponíveis e o grau de personalização necessário.
- Considere se as necessidades do serviço ou negócio poderiam ser melhor atendidas por conceitos avançados:
  - Microsserviços, computação sem servidor e orquestração se concentram nos requisitos de fluxo de trabalho, e não na administração do servidor.
  - Benefícios e cenários de uso comuns para redes definidas por software.
- Se estiver usando um CSP, crie um SLA e uma matriz de responsabilidade de segurança para identificar quem executará tarefas críticas de segurança. Garanta que os relatórios e o monitoramento dos dados de segurança em nuvem sejam integrados ao monitoramento no local e à resposta a incidentes.
- Avalie os recursos de segurança dos dispositivos incorporados e isole-os de outros dispositivos de rede.
- Implemente conceitos de arquitetura de confiança zero para validar conexões e dispositivos em vez de confiar em conceitos de limites “internos” e “externos”.



This content is only available on larger screen sizes. Please revisit this page on a larger device.